LALUM

חוברת אבטחה

מה פועל, מה נבדק ומה אינו מובטח, עם סקריפט ביקורת ותבניות הקשחה

נבדק ב-19.10.2026

lalumapp.com/security/

ד"ר עו"ד אברהם ללום

כאן מתוארים הבקרות שפועלות בפועל באתר, בפורטל הלקוחות ובמערכת העבודה של המשרד, ומה כל אחת מהן אינה עושה. כל משפט נבדק מול הקוד או מול המערכת החיה, ולא נכתב משפט שלא הצלחנו לבדוק.

איך לקרוא את העמוד

- כל טענה נבדקה ב-19.10.2026. מערכת משתנה, ולכן התאריך חלק מהטענה.
- טענה שמתארת ספק (למשל מארח מסד הנתונים) היא הצהרת הספק, מסומנת ככזו, ואינה תכונה שבנינו.
- לכל טענה יש רשומת אימות פנימית: מה נבדק, איך, ואיך חוזרים על הבדיקה. אנשי אבטחה ובודקי נאותות מוזמנים לבקש אותה.
- היכן שיש גבול להגנה, הוא כתוב מתחת לטענה עצמה.

זהות והרשאות

SEC-01

כניסה מאומתת

אזור הלקוחות, פורטל הלקוח וסביבת העבודה של המשרד דורשים התחברות. העוזר המשפטי באתר פועל רק למשתמש מחובר: פנייה אנונימית מקבלת בקשת התחברות ולא מגיעה למודל.

גבול: כלי ניתוח החוזים הציבוריים אינם דורשים התחברות. הם מתוארים בקבוצה "בינה מלאכותית".

SEC-02

אימות דו-שלבי שהמסד אוכף

לשותפים ולעורכי דין זמין אימות דו-שלבי באפליקציית אימות (TOTP), ובחשבון המשרד הוא מוגדר כחובה. את הדרישה אוכף מסד הנתונים עצמו ולא רק הממשק: רשומות רגישות כגון בדיקות זיהוי לקוח, גרסאות מסמכים ונספחים נדחות מסשן שלא עבר את הגורם השני.

SEC-03

קודי שחזור

בהפעלת האימות נוצרים שמונה קודי שחזור חד-פעמיים, ומוצגים פעם אחת. הקוד עצמו אינו נשמר, אלא גיבוב SHA-256 הקשור לחשבון. חמישה ניסיונות שגויים נועלים את השחזור לחמש עשרה דקות. שחזור מסיר את גורמי ה-TOTP הקיימים, כדי שאפשר יהיה לחבר אפליקציה חדשה.

SEC-04

הרשאת מנהל נקבעת רק בשרת

דגל מנהל הפלטפורמה אינו ניתן לשינוי מסשן של משתמש, גם לא של המשתמש עצמו, ואינו ניתן להגדרה בעת הרשמה. הוא נקבע רק בצד השרת.

SEC-20

סיסמאות: בחירה, החלפה ואיפוס

סיסמה חדשה, בהרשמה, בהחלפה ובאיפוס, חייבת לכלול לפחות 12 תווים ולא יותר מ-72 בתים. אין חובה לסימנים מיוחדים. הטופס חוסם סיסמאות נפוצות, חזרות ורצפי מקלדת, וסיסמה שבנויה מכתובת האימייל או מהשם של החשבון. הוא בודק גם אם הסיסמה הופיעה בדליפה פומבית, בשיטה שבה יוצאים מהדפדפן רק חמשת התווים הראשונים של גיבוב הסיסמה. בטופס ההחלפה צריך להזין את הסיסמה הנוכחית, והיא נבדקת מול שרת האימות. אחרי החלפה או איפוס, כל שאר ההתחברויות של החשבון מנותקות. אפשר לאפס סיסמה גם בקוד חד-פעמי שנשלח במייל, ובחשבון עם אימות דו-שלבי נדרש גם קוד האפליקציה לפני שאפשר לבחור סיסמה חדשה.

גבול: הבדיקות שבטופס, כולל בדיקת הדליפה וההשהיה אחרי ניסיונות שגויים, רצות בדפדפן. פנייה ישירה לממשק ההרשמה של ספק האימות עוקפת אותן: שם נאכף מינימום של 12 תווים בלבד, ואין הגנת סיסמאות מדולפות בצד השרת (היא זמינה רק בתוכנית מתקדמת של הספק). גם הדרישה להזין את הסיסמה הנוכחית נאכפת בטופס ולא בשרת.

בידוד בין לקוחות ובין משרדים

SEC-05

אבטחה ברמת שורה בכל הטבלאות

בכל טבלאות הנתונים מופעלת אבטחה ברמת שורה (Row Level Security): 93 מתוך 93 בבדיקה מיום 19.10.2026. הגישה לתיק מותנית בתפקיד ובשיוך למשרד, והיא נאכפת במסד הנתונים ולא רק בממשק.

גבול: הפעלת המנגנון בכל טבלה אינה הוכחה שכל מדיניות נכונה. לכן נכתבו בדיקות SQL ייעודיות לבידוד בין תיקים, חיוב וגישה לפי תפקיד, והן חלק מהקוד.

SEC-06

שמות לקוחות מוסתרים כברירת מחדל

במסכי הצוות מוצג קוד תיק במקום שם הלקוח. חשיפת השם היא פעולה מכוונת שמותרת לשותף ולעורך דין בלבד, אחרי אימות דו-שלבי עדכני, והיא נרשמת ביומן הביקורת.

גבול: זו בקרה ברמת התצוגה. הרשאת הקריאה לתיק עצמו נקבעת במסד הנתונים, כמתואר בסעיף הקודם.

SEC-07

סודות נשארים בשרת

מפתח השירות הפריבילגי של מסד הנתונים נמצא רק במשתני הסביבה של פונקציות השרת. חבילת הקוד שנשלחת לדפדפן נבדקה, ולא נמצאו בה מפתח שירות, מפתחות של ספקים או מפתחות פרטיים. בדפדפן יושב המפתח הציבורי בלבד, וההגנה על הנתונים נשענת על הסעיף הקודם.

מסמכים וקבצים

SEC-08

מאגרי קבצים פרטיים וקישורים קצרי מועד

כל ארבעת מאגרי הקבצים במערכת מוגדרים פרטיים. פתיחת קובץ מהפורטל, ופתיחת מקור של מסמך על ידי שותף או עורך דין, נעשות בקישור חתום שתוקפו שישים שניות.

גבול: קישורי עבודה פנימיים של צוות המשרד יכולים להיות בני תוקף ארוך יותר, עד שעה.

SEC-09 · הצהרת ספק

הצפנה במנוחה ובמעבר

ספק מסד הנתונים והאחסון, Supabase, מצהיר שהנתונים מוצפנים במנוחה ובמעבר.

גבול: זו הצהרת הספק ולא תכונה שבנינו. היא מכסה את הנתונים שבתוך הפלטפורמה שלו.

https://supabase.com/docs/guides/deployment/shared-responsibility-model

SEC-10 · הצהרת ספק

הסמכת הספק

Supabase מצהירה שהיא עומדת בתקן SOC 2 Type 2 ונבדקת אחת לשנה על ידי גורם חיצוני.

גבול: ההסמכה היא של הספק בלבד. לפי הספק עצמו היא אינה עוברת לסביבות שמחוץ לפלטפורמה, ואינה הסמכה של LALUM.

https://supabase.com/docs/guides/security/soc-2-compliance

תשלומים וחיבורים לצד שלישי

SEC-11

פרטי כרטיס אשראי לא עוברים אצלנו

באפליקציה אין שדות להזנת פרטי כרטיס אשראי. הזנת הפרטים מתבצעת אצל חברת הסליקה, ופרטי כרטיס אינם נשמרים במסד הנתונים של LALUM.

SEC-12

אימות אישורי תשלום

אישור תשלום מחברת הסליקה נקלט רק עם סוד משותף, שנבדק בהשוואה בזמן קבוע, ונדחה כשהסוד אינו מוגדר. כשהאישור כולל סכום, הוא חייב להתאים לסכום אבן הדרך, ואחרת האבן דרך לא מסומנת כמשולמת.

גבול: האימות הוא סוד משותף ולא חתימה קריפטוגרפית של הספק על כל הודעה.

SEC-13

אימות הודעות נכנסות מספקים אחרים

הודעות WhatsApp נקלטות רק עם חתימת HMAC-SHA256 תקפה של Meta, ונדחות כשהסוד אינו מוגדר. ה-webhook הקולי וה-webhook של החתימה האלקטרונית נדחים כשהסוד שלהם אינו תואם או אינו מוגדר.

דפדפן ורשת

SEC-14

כותרות אבטחה ומדיניות תוכן אוכפת

האתר מוגש ב-HTTPS עם HSTS לשנה הכולל תתי דומיינים. מדיניות תוכן (CSP) אוכפת, ולא רק מדווחת, אוסרת סקריפטים מקוונים ואובייקטים, מגבילה מאיפה נטענים סקריפטים, ומונעת הטמעת האתר במסגרת של אתר זר. מוגדרות גם כותרות nosniff, מדיניות רפרר, מדיניות הרשאות דפדפן ובידוד חלונות.

גבול: המדיניות מתירה סגנונות מקוונים. סקריפטים נטענים רק מהמארחים הרשומים בה, ובהם שירותי צד שלישי של האתר הציבורי.

מניעת ניצול לרעה

SEC-15

מגבלות קצב

טפסי הפנייה, קביעת פגישה, ניתוח החוזים והעוזר המשפטי מוגבלים לפי מקור הפנייה. לעוזר המשפטי יש גם מכסה יומית לכל משתמש ומכסה יומית כוללת. כתובת ה-IP של מבקר אינה נשמרת: נשמר גיבוב שמשמש את המגבלה בלבד.

תיעוד, יושרה ושמירה

SEC-16

יומן ביקורת בשרשרת גיבובים

כל רשומה ביומן הביקורת של משרד כוללת גיבוב SHA-256 של הרשומה שלפניה, ויש פונקציית בדיקה שמאתרת את הרשומה הראשונה שבה השרשרת נשברת. עדכון או מחיקה של רשומה נדחים בידי המסד, וכתובת דוא"ל אינה נרשמת ביומן.

גבול: השרשרת מגלה שינוי בדיעבד, והיא אינה אחסון חיצוני בלתי ניתן לשינוי.

SEC-17

מחיקה לפי תקופות שמירה

משימות מתוזמנות רצות בכל יום: מחיקת מסמכי תיק שהלקוח הסכים למחיקתם שלושים יום אחרי סיום הטיפול, אלא אם חל עיכוב משפטי, והמחיקה נרשמת ביומן הביקורת. מחיקת פניות מהאתר בתום תקופת השמירה שלהן. ריקון תוכן הודעות WhatsApp אחרי שלושים יום, כשמועד וכיוון ההודעה נשארים. ופינוי רשומות זמניות של מנגנון הסרת הזיהוי.

בינה מלאכותית

SEC-18

הסרת פרטים מזהים לפני ניתוח

במערכת העבודה של המשרד שמות לקוחות וכתובות מוחלפים באסימונים כגון [CLIENT_NAME_2] לפני שהטקסט נשלח לניתוח, והמיפוג חזרה לשמות האמיתיים נשמר בדפדפן למשך הסשן בלבד ומופעל בייצוא.

גבול: הזיהוי מבוסס כללים וזיהוי תבניות, ואינו מבטיח זיהוי של כל פרט. לכן ההחלטה המקצועית נשארת בידי עורך דין, והסרת הזיהוי היא שכבת הגנה ולא תחליף לשיקול דעת.

SEC-19

כלים ציבוריים: שימו לב למה שמעלים

כלי ניתוח החוזים הציבוריים באתר פועלים ללא התחברות ושולחים את הטקסט שהוזן אליהם לספק בינה מלאכותית חיצוני לצורך הניתוח. אין להזין אליהם מסמכים חסויים או מידע מזהה של אחרים.

גבול: פלטי הכלים אינם ייעוץ משפטי ואינם מחליפים עורך דין.

מה העמוד הזה אינו טוען

- אין כאן טענה שמערכות LALUM עברו תקן או הסמכה כגון ISO 27001 או SOC 2. ההסמכה שמוזכרת למטה היא של הספק, ואינה עוברת אלינו.
- אין כאן טענה לבדיקת חדירה חיצונית שפורסמה.

- אין סריקת נוזקות אוטומטית של קבצים שלקוח מעלה לפורטל. הקבצים נשמרים במאגר פרטי עם מגבלת גודל ונפתחים בקישור חתום בלבד.
- אין כאן הבטחה שמערכת מסוימת חסינה. אף מערכת אינה חסינה, והעמוד מתאר בקרות ולא ערבות.
- אין כאן טענות על הגדרות שבידי ספקים ושלא נבדקו מול המערכת, לרבות תצורת רשת הפצה וחומת אש ברמת הדומיין.

בדקו בעצמכם: סקריפט ותבניות

שלושה דברים שאפשר לקחת ולהשתמש בהם. לכל אחד כתוב אם הוא רץ אצלנו או שהוא תבנית, ומה תוקן בהשוואה לגרסאות נפוצות.

TPL-01 סקריפט ביקורת למסד Supabase (רץ אצלנו)

שאילתת קריאה בלבד אחת שמריצים ב-SQL Editor של Supabase. היא לא משנה דבר, ומחזירה רשימת מוקדים לבדיקה לפי חומרה. הרצנו אותה על מסד הנתונים של LALUM ב-19.10.2026.

- בודק: טבלאות ללא RLS, מדיניות פתוחה (true) ל-anon ול-PUBLIC, פונקציות SECURITY DEFINER הזמינות לאורחים או ללא search_path קבוע, Views שעוקפים RLS, מאגרי קבצים ציבוריים, ומדיניות פתוחה לכל משתמש מחובר.
- התוצאה אצלנו: אפס טבלאות ללא RLS, אפס פונקציות או Views חשופים לאורחים, אפס מאגרי קבצים ציבוריים. נשארו מוקד אחד בחומרה גבוהה ומוקד אחד בינונית, ושניהם נתוני ייחוס שמיועדים להיות פתוחים: שלושה קריטריוני ניתוח חוזים לדוגמה ורשימת מחירים. וכן חמש פונקציות עזר לבדיקה ידנית, שמחזירות ערך פשוט בלבד (כן או לא, או סטטוס).
- כל שורה היא מוקד ולא פסק דין. מוקדי REVIEW ו-MEDIUM דורשים החלטה אנושית אם הגישה הפתוחה מכוונת.

```
-- ============================================================================
-- LALUM: Supabase security audit (read only)
-- Paste into the Supabase SQL Editor and run. It changes nothing: one SELECT.
--
-- Checks (severity in brackets):
--   1  Tables in public with Row Level Security off                    [CRITICAL]
--   2  Policies open to everyone (USING/CHECK true) for anon or PUBLIC [HIGH]
--   3  SECURITY DEFINER functions callable by anon or PUBLIC           [HIGH]
--   4  Views that bypass RLS (not security_invoker) and are readable   [HIGH]
--   5  Public storage buckets                                          [HIGH]
--   6  Policies open to every signed in user (USING/CHECK true)        [MEDIUM]
--   7  Anonymous write policies with no identity check                 [MEDIUM]
--   8  SECURITY DEFINER functions with no search_path pinned           [MEDIUM]
--   9  SECURITY DEFINER functions for signed in users, no guard found  [REVIEW]
--  10  Tables with RLS on and no policy; policies for PUBLIC that      [INFO]
--      call an auth helper (fail for anon, so only a naming nit)
--  11  Extensions installed in public                                  [LOW]
--
-- Reading the result: every row is a lead, not a verdict. Row 6 and row 9 need a
-- human to decide whether the open access is intended (a public price list is;
-- an internal playbook is not). Row 9 is a heuristic: it looks for a call to an
-- auth or role helper inside the function body. Edit guard_pattern below to the
-- names of your own helpers. A match does not prove the check is correct, and a
-- miss does not prove it is missing.
-- ============================================================================
```

```
with
settings as (
  select '(auth\.(uid|jwt|role)\
(|_is_admin|_my_role|_my_firm_id|_mgr_ok|_fin_can|_is_partner_of|_is_staff_on|_can_view_matter|_client_can|
_matter_firm|_admin_ok|_mfa_ok)'::text as guard_pattern
),
tbl as (
  select c.oid, c.relname, c.relrowsecurity as rls
  from pg_class c
  join pg_namespace n on n.oid = c.relnamespace
  where n.nspname = 'public' and c.relkind in ('r', 'p')
),
pol as (
  select schemaname, tablename, policyname, permissive, cmd,
         roles::text[] as roles,
         lower(btrim(coalesce(qual, ''))) as q,
         lower(btrim(coalesce(with_check, ''))) as wc
  from pg_policies
  where schemaname in ('public', 'storage')
),
findings as (
  select 1 as rank, 'CRITICAL' as severity, 'RLS disabled' as category,
         'public.' || relname as object,
         'Row Level Security is off: anyone holding the anon key can read and write, per the table grants.'
as detail,
         'ALTER TABLE public.' || quote_ident(relname) || ' ENABLE ROW LEVEL SECURITY;' as fix
  from tbl where not rls

  union all
  select 2, 'HIGH', 'Open policy for anon or PUBLIC',
         schemaname || '.' || tablename,
         'policy "' || policyname || '" ' || cmd || ' to {' || array_to_string(roles, ',') || '} using ['
|| q || '] check [' || wc || ']',
         'Replace true with an ownership or tenant condition, or drop the policy.'
  from pol
  where permissive = 'PERMISSIVE' and (q = 'true' or wc = 'true') and roles && array['public', 'anon']

  union all
  select 2, 'HIGH', 'SECURITY DEFINER callable by anon or PUBLIC',
         p.oid::regprocedure::text,
         'Any visitor can call this function and it runs with its owner''s rights.',
         'REVOKE EXECUTE ON FUNCTION ' || p.oid::regprocedure::text || ' FROM PUBLIC, anon;'
  from pg_proc p
  where p.pronamespace = 'public'::regnamespace and p.prosecdef
    and has_function_privilege('anon', p.oid, 'execute')

  union all
  select 2, 'HIGH', 'View bypasses RLS',
         'public.' || c.relname,
         case c.relkind when 'm' then 'Materialized views are not subject to RLS.' else 'View runs with its
owner''s rights (' || pg_get_userbyid(c.relowner) || ') and ignores the caller''s RLS.' end,
         case c.relkind when 'm' then 'REVOKE SELECT ON public.' || quote_ident(c.relname) || ' FROM anon,
authenticated;'
                        else 'ALTER VIEW public.' || quote_ident(c.relname) || ' SET (security_invoker =
true);' end
  from pg_class c
  where c.relnamespace = 'public'::regnamespace and c.relkind in ('v', 'm')
    and not exists (select 1 from unnest(coalesce(c.reloptions, '{}')) o where o ~ '^security_invoker=
(true|on|1)$')
    and (has_table_privilege('anon', c.oid, 'select') or has_table_privilege('authenticated', c.oid,
'select'))

  union all
  select 2, 'HIGH', 'Public storage bucket', 'storage.' || id,
```

```
         'Files in this bucket are readable by URL without any signature.',
         'UPDATE storage.buckets SET public = false WHERE id = ' || quote_literal(id) || ';'
  from storage.buckets where public

  union all
  select 3, 'MEDIUM', 'Open policy for every signed in user',
         schemaname || '.' || tablename,
         'policy "' || policyname || '" ' || cmd || ' to {' || array_to_string(roles, ',') || '} using ['
|| q || '] check [' || wc || ']',
         'If sign-up is open this means any stranger. Restrict to a role or tenant, unless the data is
meant to be public.'
  from pol
  where permissive = 'PERMISSIVE' and (q = 'true' or wc = 'true')
    and roles && array['authenticated'] and not (roles && array['public', 'anon'])

  union all
  select 3, 'MEDIUM', 'Anonymous write policy, no identity check',
         pl.schemaname || '.' || pl.tablename,
         'policy "' || pl.policyname || '" ' || pl.cmd || ' to {' || array_to_string(pl.roles, ',') || '}
using [' || pl.q || '] check [' || pl.wc || ']',
         'A visitor with no account may write here. Confirm it is meant to, and that the check limits
what.'
  from pol pl, settings s
  where pl.permissive = 'PERMISSIVE' and pl.cmd in ('INSERT', 'UPDATE', 'DELETE', 'ALL')
    and pl.roles && array['public', 'anon'] and not (pl.q = 'true' or pl.wc = 'true')
    and (pl.q || ' ' || pl.wc) !~* s.guard_pattern

  union all
  select 5, 'INFO', 'Policy applies to PUBLIC but requires an identity',
         pl.schemaname || '.' || pl.tablename,
         'policy "' || pl.policyname || '" ' || pl.cmd || ' has no TO clause, so it covers PUBLIC, but its
condition calls an auth or role helper and fails for anon.',
         'Optional: add TO authenticated so the intent is explicit.'
  from pol pl, settings s
  where pl.permissive = 'PERMISSIVE' and pl.cmd in ('INSERT', 'UPDATE', 'DELETE', 'ALL')
    and pl.roles && array['public', 'anon'] and not (pl.q = 'true' or pl.wc = 'true')
    and (pl.q || ' ' || pl.wc) ~* s.guard_pattern

  union all
  select 3, 'MEDIUM', 'SECURITY DEFINER without a pinned search_path',
         p.oid::regprocedure::text,
         'A mutable search_path lets a caller shadow objects the function relies on.',
         'ALTER FUNCTION ' || p.oid::regprocedure::text || ' SET search_path = public, pg_temp;'
  from pg_proc p
  where p.pronamespace = 'public'::regnamespace and p.prosecdef
    and not exists (select 1 from unnest(coalesce(p.proconfig, '{}')) cfg where cfg like 'search_path=%')

  union all
  select 4, 'REVIEW', 'SECURITY DEFINER for signed in users, no guard found',
         p.oid::regprocedure::text,
         'Callable by any signed in user and no call to an auth or role helper was found in the body
(heuristic).',
         'Read the function. Add an explicit check on auth.uid() or a role, or revoke EXECUTE from
authenticated.'
  from pg_proc p, settings s
  where p.pronamespace = 'public'::regnamespace and p.prosecdef
    and has_function_privilege('authenticated', p.oid, 'execute')
    and not has_function_privilege('anon', p.oid, 'execute')
    and pg_get_functiondef(p.oid) !~* s.guard_pattern

  union all
  select 5, 'INFO', 'RLS on, no policy', 'public.' || t.relname,
         'Deny all for the API roles. Correct if only server code with the service role reads this table.',
         'None needed if intended.'
  from tbl t
```

```
  where t.rls and not exists (select 1 from pg_policies pp where pp.schemaname = 'public' and pp.tablename
= t.relname)

  union all
  select 6, 'LOW', 'Extension in public', e.extname,
         'Extensions in public widen the API surface.',
         'ALTER EXTENSION ' || quote_ident(e.extname) || ' SET SCHEMA extensions;'
  from pg_extension e join pg_namespace n on n.oid = e.extnamespace
  where n.nspname = 'public'
)
select severity, category, object, detail, fix
from findings
order by rank, category, object;
```

מה תוקן לעומת גרסאות נפוצות

- גרסה נפוצה של בדיקה כזו מתמקדת רק במדיניות שפתוחה ל-anon. היא מפספסת מדיניות true ל-authenticated, ובהרשמה פתוחה זה כל אדם זר.
- גרסה נפוצה ממיינת את החומרות לפי אלפבית, ואז WARNING מופיע לפני CRITICAL. כאן מיון לפי דירוג מספרי.
- מדיניות בלי סעיף TO חלה על PUBLIC, אבל אם התנאי שלה דורש זהות מחוברת היא נכשלת לאורח. כאן היא מסווגת כהערה ולא כפרצה.

TPL-02 מאגר קבצים פרטי עם מדיניות בעלות (תבנית לביצוע)

תבנית למאגר שבו כל משתמש רואה רק את התיקייה שלו, עם מגבלת גודל וסוגים. ארבעת מאגרי הקבצים של LALUM פרטיים, ומדיניות הגישה אליהם נבנתה על אותו עיקרון: ב-client-files לפי בעלות, וב-matter-originals לפי משרד, תפקיד ואימות דו-שלבי.

- הגישה לקובץ נעשית בקישור חתום קצר מועד (createSignedUrl), לא בכתובת ציבורית. אצלנו הקישורים בפורטל תקפים שישים שניות.
- בגישה לפי משרד ולא לפי משתמש בודד, משווים את התיקייה הראשונה לפונקציית השיוך שלכם, בטקסט: (storage.foldername(name))[1] = (select public.my_firm_id())::text. כך עובד matter-originals אצלנו.
- אצלנו ב-client-files יש מגבלת גודל של 25MB, ורשימת סוגים מותרים מוגדרת ב-matter-originals בלבד.

```
-- A private bucket with an owner folder. Replace the bucket id and the types.
insert into storage.buckets (id, name, public, file_size_limit, allowed_mime_types)
values ('client-documents', 'client-documents', false, 10485760,
        array['application/pdf', 'image/jpeg', 'image/png'])
on conflict (id) do update
  set public = false,
      file_size_limit = excluded.file_size_limit,
      allowed_mime_types = excluded.allowed_mime_types;

-- The first folder of every object path is the owner's user id.
create policy "documents: read own" on storage.objects
  for select to authenticated
  using (bucket_id = 'client-documents'
         and (storage.foldername(name))[1] = (select auth.uid())::text);

create policy "documents: upload to own folder" on storage.objects
  for insert to authenticated
  with check (bucket_id = 'client-documents'
              and (storage.foldername(name))[1] = (select auth.uid())::text);
```

```
create policy "documents: update own" on storage.objects
  for update to authenticated
  using (bucket_id = 'client-documents'
         and (storage.foldername(name))[1] = (select auth.uid())::text)
  with check (bucket_id = 'client-documents'
              and (storage.foldername(name))[1] = (select auth.uid())::text);

create policy "documents: delete own" on storage.objects
  for delete to authenticated
  using (bucket_id = 'client-documents'
         and (storage.foldername(name))[1] = (select auth.uid())::text);
```

מה תוקן לעומת גרסאות נפוצות

- שם העמודה הוא file_size_limit. הנוסח max_file_size שמופיע בהדרכות רבות אינו קיים, והפקודה נכשלת.
- אין להמיר את שם התיקייה ל-uuid בתוך המדיניות. נתיב שאינו uuid זורק שגיאה ועלול להכשיל שאילתה שלמה. משווים בטקסט.
- כותבים (select auth.uid()) ולא auth.uid() ישירות, כדי שהערך יחושב פעם אחת בשאילתה.
- מדיניות UPDATE צריכה גם WITH CHECK, אחרת אפשר להעביר קובץ לתיקייה של אחר דרך שינוי שם.
- אל תתירו html או svg במאגר שנפתח בדפדפן בלי כותרת הורדה. קובץ כזה עלול להריץ סקריפט.

TPL-03 סריקת נוזקות לפני שמירה (תבנית לביצוע, לא פרוסה אצלנו)

הרעיון: הקובץ לא נכתב למאגר ישירות מהדפדפן. הוא עובר בפונקציית שרת, נבדק, ורק קובץ תקין נשמר. כרגע LALUM אינה סורקת נוזקות בקבצים שלקוח מעלה לפורטל, והם מגיעים ישירות למאגר פרטי עם מגבלת גודל ובלי סריקה.

- הזרימה: הלקוח שולח לפונקציה עם הטוקן שלו, הפונקציה מאמתת זהות, גודל וסוג, שולחת למנוע סריקה, ורק אחרי תשובה נקייה כותבת למאגר עם מפתח השירות, תחת תיקיית הבעלים. כדי שההעלאה הישירה לא תעקוף את הבדיקה, מסירים את מדיניות ה-INSERT של משתמשים מחוברים באותו מאגר.
- לקבצים גדולים אין להמתין סינכרונית. מעלים למאגר הסגר נעול, מנוע רקע סורק, וקובץ נקי מועבר למאגר היעד וקובץ נגוע נמחק עם התראה ורשומה ביומן. מאגר הסגר נעול (matter-quarantine) קיים במסד, ואין כרגע בקוד שימוש בו.

```
// Sketch of the gate. Not deployed in LALUM. SCANNER_URL is a ClamAV REST
// service that you operate, so the file never leaves your infrastructure.
const MAX_BYTES = 10 * 1024 * 1024;
const MAGIC: Record<string, number[]> = {
  "application/pdf": [0x25, 0x50, 0x44, 0x46],
  "image/png": [0x89, 0x50, 0x4e, 0x47],
  "image/jpeg": [0xff, 0xd8, 0xff],
};

class HttpError extends Error { constructor(public status: number) { super(String(status)); } }

async function cleanOrThrow(file: File): Promise<Uint8Array> {
  if (file.size > MAX_BYTES) throw new HttpError(413);
  const buf = new Uint8Array(await file.arrayBuffer());
  const sig = MAGIC[file.type];
  if (!sig || !sig.every((b, i) => buf[i] === b)) throw new HttpError(415); // the declared type must match
the bytes
  const r = await fetch(SCANNER_URL, { method: "POST", body: buf, signal: AbortSignal.timeout(20_000) });
  if (!r.ok) throw new HttpError(503);                // scanner down: fail closed, store nothing
  const verdict = await r.json();                     // { infected: boolean }
  if (verdict.infected !== false) throw new HttpError(422);
```

```
  return buf;
}
```

מה תוקן לעומת גרסאות נפוצות

- אין לשלוח מסמכים משפטיים לשירות סריקה ציבורי. לפי התיעוד של VirusTotal, קבצים שנשלחים אליו בשימוש הרגיל עשויים להיות משותפים מעבר לארגון שלכם, ורק מסלול Private Scanning בתשלום מחזיק אותם בתוך הארגון. לכן מנוע שאתם מפעילים בעצמכם (ClamAV) או בדיקה לפי גיבוב בלבד, בלי העלאה.
- סריקה שמחזירה סטטוס "בתור" מחזירה אפס זיהויים. קוד שקורא את התוצאה מיד ולא ממתין לסטטוס "הושלם" מעביר כל קובץ. נדרש polling עם תקרת זמן, וכשל סגור בתום התקרה.
- סוג הקובץ שהלקוח מצהיר עליו אינו ראיה. בודקים את הבתים הראשונים של הקובץ מול הסוג המוצהר.
- שם הקובץ מגיע מהלקוח. מנקים אותו או מייצרים שם בצד השרת, ואין להשתמש בו בנתיב כפי שהוא.
- תקלה במנוע הסריקה חייבת להיכשל סגור: הקובץ לא נשמר. פתיחה שקטה בכשל היא הדרך הנפוצה להפוך בקרה לקישוט.
- מגבלות גודל וזמן ריצה בפונקציית קצה חלות. מה שלא נכנס בהן הולך למסלול ההסגר.

https://docs.virustotal.com/docs/private-scanning

דיווח על חולשה

אם מצאתם חולשה או חשש אבטחה, פנו אל avraham@lalum.co. כתבו מה ראיתם, באיזו כתובת, ואיך אפשר לשחזר, ובלי לגשת למידע של אחרים או להשתמש בחולשה מעבר לנדרש כדי להדגים אותה.

פרטי הקשר מפורסמים גם בקובץ security.txt, בדרך המקובלת לכך.

העמוד מספק מידע כללי על בקרות אבטחה ואינו התחייבות חוזית ואינו ייעוץ משפטי. התחייבות כזו, אם תינתן, תיכתב בהסכם מול לקוח.